架构

NetApp Solutions

NetApp
July 19, 2022

This PDF was generated from https://docs.netapp.com/zh-cn/netapp-solutions/ehc/ncvs/ncvs-gc-architecture_overview.html on July 19, 2022. Always check docs.netapp.com for the latest.

目录

架构 1
概述 1
Cloud Volumes Service 架构 1
控制平面架构 4
数据平台架构 6
传输中的数据加密 7
空闲数据加密 10
防火墙： 10

架构

概述

"上一篇：安全注意事项和攻击面。"

信任云解决方案 的一部分是了解架构及其安全保护方式。本节将介绍Google中Cloud Volumes Service 架构的不同方面、以帮助缓解对数据安全保护的潜在担忧、并指出可能需要执行其他配置步骤才能实现最安全的部署。

Cloud Volumes Service 的通用架构可细分为两个主要组件：控制平面和数据平面。

控制面板

Cloud Volumes Service 中的控制平台是由Cloud Volumes Service 管理员和NetApp原生 自动化软件管理的后端基础架构。此平台对最终用户完全透明、并包括网络、存储硬件、软件更新等、可帮助为Cloud Volumes Service 等驻留在云中的解决方案 提供价值。

数据平面

Cloud Volumes Service 中的数据平面包括实际数据卷和整体Cloud Volumes Service 配置(例如访问控制、Kerberos身份验证等)。数据平面完全由Cloud Volumes Service 平台的最终用户和使用者控制。

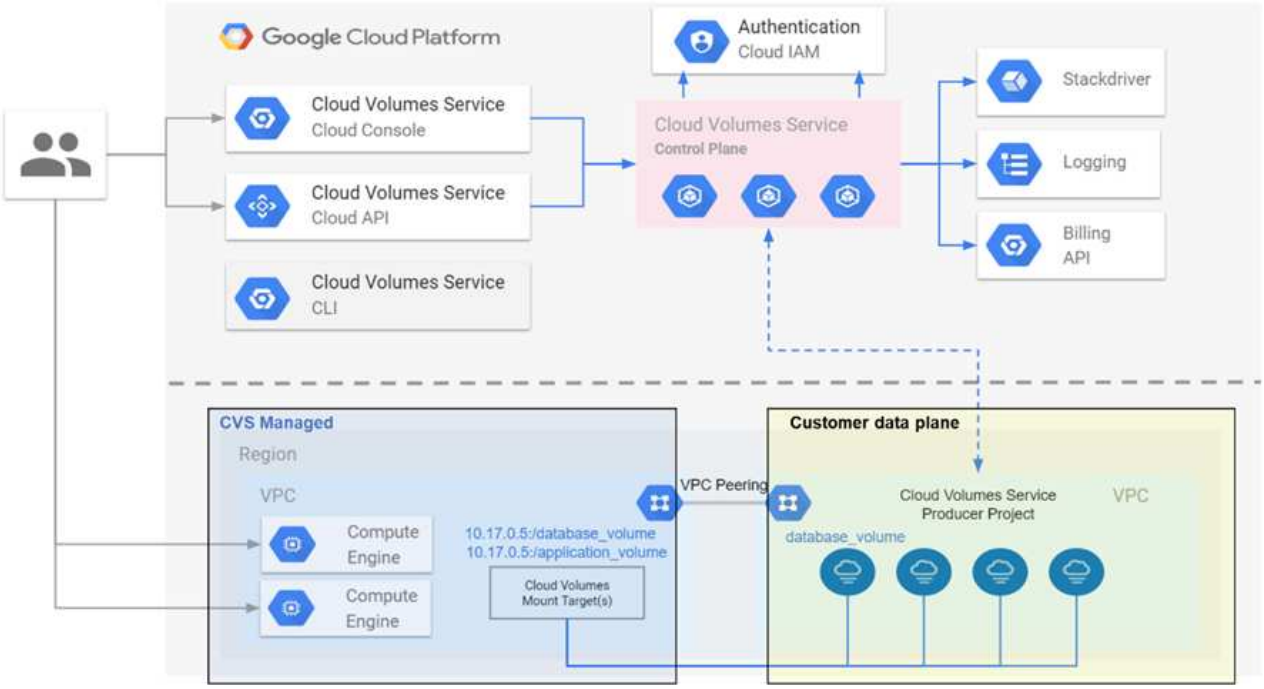
每个平面的安全保护和管理方式各不相同。以下各节将从Cloud Volumes Service 架构概述开始介绍这些差异。

"接下来：Cloud Volumes Service 架构。"

Cloud Volumes Service 架构

Cloud Volumes Service 采用与其他Google Cloud原生 服务类似的方式、例如CloudSQL、Google Cloud VMware引擎(GCVE)和文件存储库 "Google PSA" 交付服务。在PSA中、服务构建在服务生产者项目中、该项目使用 "VPC网络对等" 以连接到服务使用者。服务生产者由NetApp提供和运营、服务使用者是客户项目中的VPC、负责托管要访问Cloud Volumes Service 文件共享的客户端。

下图、引用自 "架构部分" 显示了Cloud Volumes Service 文档的概要视图。



虚线上方的部分显示服务的控制平面、控制卷生命周期。虚线下方的部分显示数据平面。左侧蓝色框表示用户VPC (服务使用者)、右侧蓝色框表示NetApp提供的服务生产者。两者均通过VPC对等连接。

租户模式

在Cloud Volumes Service 中、各个项目被视为唯一租户。这意味着、卷、Snapshot副本等操作是按项目执行的。换言之、所有卷均归在中创建它们的项目所有、默认情况下、只有该项目才能管理和访问其中的数据。这被视为服务的控制面板视图。

共享 **vPC**

在数据平面视图中、Cloud Volumes Service 可以连接到共享VPC。您可以在托管项目中或连接到共享VPC的某个服务项目中创建卷。连接到此共享VPC的所有项目(主机或服务)均可访问网络层(TCP/IP)上的卷。由于共享VPC上具有网络连接的所有客户端都可能通过NAS协议访问数据、因此必须使用单个卷上的访问控制(例如、NFS导出的用户/组访问控制列表(ACL)和主机名/IP地址)来控制谁可以访问数据。

每个客户项目最多可以将Cloud Volumes Service 连接到五个vPC。在控制平面上、您可以通过该项目管理所有已创建的卷、无论这些卷连接到哪个VPC。在数据平面上、VPC彼此隔离、每个卷只能连接到一个VPC。

对各个卷的访问由特定协议(NFS/SMB)访问控制机制控制。

换言之、在网络层、连接到共享VPC的所有项目都能够看到卷、而在管理端、控制平面仅允许所有者项目查看卷。

VPC服务控制

VPC服务控制功能可围绕连接到互联网且可在全球访问的Google Cloud服务建立访问控制边界。这些服务可通过用户身份提供访问控制、但不能限制发出哪些网络位置请求。VPC服务控制通过引入限制对定义的网络的访问的功能来缩小这一差距。

Cloud Volumes Service 数据平面不会连接到外部Internet、而是连接到具有明确定义的网络边界(边界)的私

有VPC。在该网络中、每个卷都使用特定于协议的访问控制。任何外部网络连接均由Google Cloud项目管理员明确创建。但是、控制平面不提供与数据平面相同的保护、任何人都可以使用有效凭据("JWT令牌"）。

简而言之、Cloud Volumes Service 数据平面可提供网络访问控制功能、无需支持VPC服务控制、也不明确使用VPC服务控制。

数据包嗅探/跟踪注意事项

数据包捕获对于解决网络问题或其他问题(例如NAS权限、LDAP连接等)非常有用、但也可以恶意使用数据包捕获来获取有关网络IP地址、MAC地址、用户和组名称以及端点上使用的安全级别的信息。由于配置Google Cloud网络、VPC和防火墙规则的方式、如果没有用户登录凭据或、则很难获取对网络数据包的不必要访问 "JWT令牌" 迁移到云实例。只有端点(如虚拟机(VM))才可以捕获数据包、只有VPC内部的端点才可以捕获数据包、除非使用共享VPC和/或外部网络通道/IP转发明确允许外部流量传输到端点。无法嗅探客户端外部的流量。

使用共享VPC时、使用NFS Kerberos和/或进行动态加密 "SMB加密" 可以屏蔽从跟踪中获取的大部分信息。但是、某些流量仍以纯文本形式发送、例如 "DNS" 和 "LDAP查询"。下图显示了从Cloud Volumes Service 发起的纯文本LDAP查询中捕获的数据包以及公开的潜在标识信息。Cloud Volumes Service 中的LDAP查询当前不支持加密或基于SSL的LDAP。CVS-SW和CVS-Performance都支持LDAP签名。

> unixUserPassword由LDAP查询、不会以纯文本形式发送、而是以盐哈希形式发送。默认情况下、Windows LDAP不会填充unixUserPassword字段。只有在需要利用Windows LDAP通过LDAP交互式登录到客户端时、才需要此字段。Cloud Volumes Service 不支持对实例进行交互式LDAP登录。

下图显示了通过AUTH_SYS捕获NFS旁边的NFS Kerberos对话中的数据包捕获。请注意、跟踪中提供的信息在这两者之间有何不同、以及启用动态加密如何为NAS流量提供更高的整体安全性。

IP addresses of the NFS client and CVS instance

Genericized NFS call/reply

No.	Time	Source	Destination	Protocol	Length	Info
380	9.218014	10.193.67.225	10.193.67.219	NFS	346	V4 Call (Reply In 381)
381	9.218480	10.193.67.219	10.193.67.225	NFS	426	V4 Reply (Call In 380)
382	9.218641	10.193.67.225	10.193.67.219	NFS	370	V4 Call (Reply In 397)
397	9.369035	10.193.67.219	10.193.67.225	NFS	458	V4 Reply (Call In 382)

```
> Frame 381: 426 bytes on wire (3408 bits), 426 bytes captured (3408 bits)
> Ethernet II, Src: IntelCor_7f:da:bc (90:e2:ba:7f:da:bc), Dst: VMware_a0:2c:2d (00:50:56:a0:2c:2d)
> Internet Protocol Version 4, Src: 10.193.67.219, Dst: 10.193.67.225
> Transmission Control Protocol, Src Port: 2049, Dst Port: 738, Seq: 6305, Ack: 6569, Len: 360
> Remote Procedure Call, Type:Reply XID:0xef5e998d
v GSS-Wrap
    Length: 300
    GSS Data: 050407ff0000000000000000025913451ee1d43d298cf3031…
  > krb5_blob: 050407ff0000000000000000025913451ee1d43d298cf3031…
v Network File System
    [Program Version: 4]
    [V4 Procedure: COMPOUND (1)]
```

GSS wrapped NFS calls/replies with no other identifying information

IP addresses of the NFS client and CVS instance

Detailed NFS call types and file handle information

No.	Time	Source	Destination	Protocol	Length	Info
33	0.958480	10.193.67.201	10.193.67.204	NFS	458	V4 Reply (Call In 32) OPEN StateID: 0x0481
34	0.958784	10.193.67.204	10.193.67.201	NFS	306	V4 Call (Reply In 35) SETATTR FH: 0x6c07918a
35	0.959284	10.193.67.201	10.193.67.204	NFS	350	V4 Reply (Call In 34) SETATTR

```
  > Opcode: PUTFH (22)
  > Opcode: SETATTR (34)
  v Opcode: GETATTR (9)
      Status: NFS4_OK (0)
    v Attr mask[0]: 0x0010011a (Type, Change, Size, FSID, FileId)
      > reqd_attr: Type (1)
      > reqd_attr: Change (3)
      > reqd_attr: Size (4)
      > reqd_attr: FSID (8)
      v reco_attr: FileId (20)
          fileid: 9232254136597092620
    v Attr mask[1]: 0x00b0a03a (Mode, NumLinks, Owner, Owner_Group, Space_Used, Time_Access, Time_Metadata, Time_Modify, Mounted_on_FileId)
      v reco_attr: Mode (33)
        > mode: 0644, Name: Unknown, Read permission for owner, Write permission for owner, Read permission for group, Read permission for others
      > reco_attr: NumLinks (35)
      v reco_attr: Owner (36)
        > fattr4_owner: root@NTAP.LOCAL
      v reco_attr: Owner_Group (37)
        > fattr4_owner_group: root@NTAP.LOCAL
      > reco_attr: Space_Used (45)
      > reco_attr: Time_Access (47)
      > reco_attr: Time_Metadata (52)
      > reco_attr: Time_Modify (53)
      > reco_attr: Mounted_on_FileId (55)
```

File ID

Permission information

Owner and group ID strings

VM网络接口

攻击者可能会尝试的一个技巧是、在中向虚拟机添加新的网络接口卡(Network Interface Card、NIC) "混杂模式"(端口镜像)或在现有NIC上启用混杂模式以嗅探所有流量。在Google Cloud中、添加新的NIC需要完全关闭虚拟机、这样会创建警报、因此攻击者无法在无人察觉的情况下执行此操作。

此外、NIC根本无法设置为混杂模式、并会在Google Cloud中触发警报。

"接下来：控制平台架构。"

控制平面架构

"先前版本：Cloud Volumes Service 架构。"

对Cloud Volumes Service 执行的所有管理操作均通过API完成。集成到GCP云控制台的Cloud Volumes Service管理也使用Cloud Volumes Service API。

身份和访问管理

身份和访问管理 ("IAM")是一项标准服务、可用于控制对Google Cloud项目实例的身份验证(登录)和授权(权限)。Google IAM可提供权限授权和删除的完整审核跟踪。目前、Cloud Volumes Service 不提供控制平面审核。

授权/权限概述

IAM为Cloud Volumes Service 提供内置的粒度权限。您可以找到 "在此填写粒度权限列表"。

IAM还提供了两个预定义角色、称为`netappcloudvolumes.admin`和`netappcloudvolumes.viewer`。可以将这些角色分配给特定用户或服务帐户。

分配适当的角色和权限以允许IAM用户管理Cloud Volumes Service。

使用粒度权限的示例包括：

- 仅使用获取/列表/创建/更新权限构建自定义角色、以使用户无法删除卷。
- 使用仅具有`snapshot.*`权限的自定义角色创建用于构建应用程序一致的Snapshot集成的服务帐户。
- 构建自定义角色、将`volumereplication *`委派给特定用户。

服务帐户

通过脚本或进行Cloud Volumes Service API调用 "Terraform"、您必须创建一个具有`角色/netappcloudvolumes.admin`角色的服务帐户。您可以使用此服务帐户通过两种不同的方式生成对Cloud Volumes Service API请求进行身份验证所需的JWT令牌：

- 生成JSON密钥并使用Google API从该密钥派生JWT令牌。这是最简单的方法、但涉及手动密钥(JSON密钥)管理。
- 使用 … "服务帐户模拟" 使用`Roles/iam.serviceAccountTokenCreator`。代码(脚本、Terraform等)运行 "应用程序默认凭据" 并模拟服务帐户以获取其权限。此方法反映了Google的安全最佳实践。

请参见 "正在创建服务帐户和私钥" 有关详细信息、请参见Google云文档。

Cloud Volumes Service API

Cloud Volumes Service API使用基于REST的API、并使用HTTPS (TLSv1.2)作为底层网络传输。您可以找到最新的API定义 "此处" 以及有关如何使用API的信息、请参见 "Google云文档中的Cloud Volumes API"。

API端点由NetApp使用标准HTTPS (TLSv1.2)功能进行操作和保护。

JWT令牌

使用JWT承载令牌对API进行身份验证 ("RFC-7519"）。必须使用Google Cloud IAM身份验证获取有效的JWT令牌。必须通过提供服务帐户JSON密钥从IAM提取令牌来完成此操作。

审核日志记录

目前、没有用户可访问的控制平面审核日志。

"接下来：数据平面架构。"

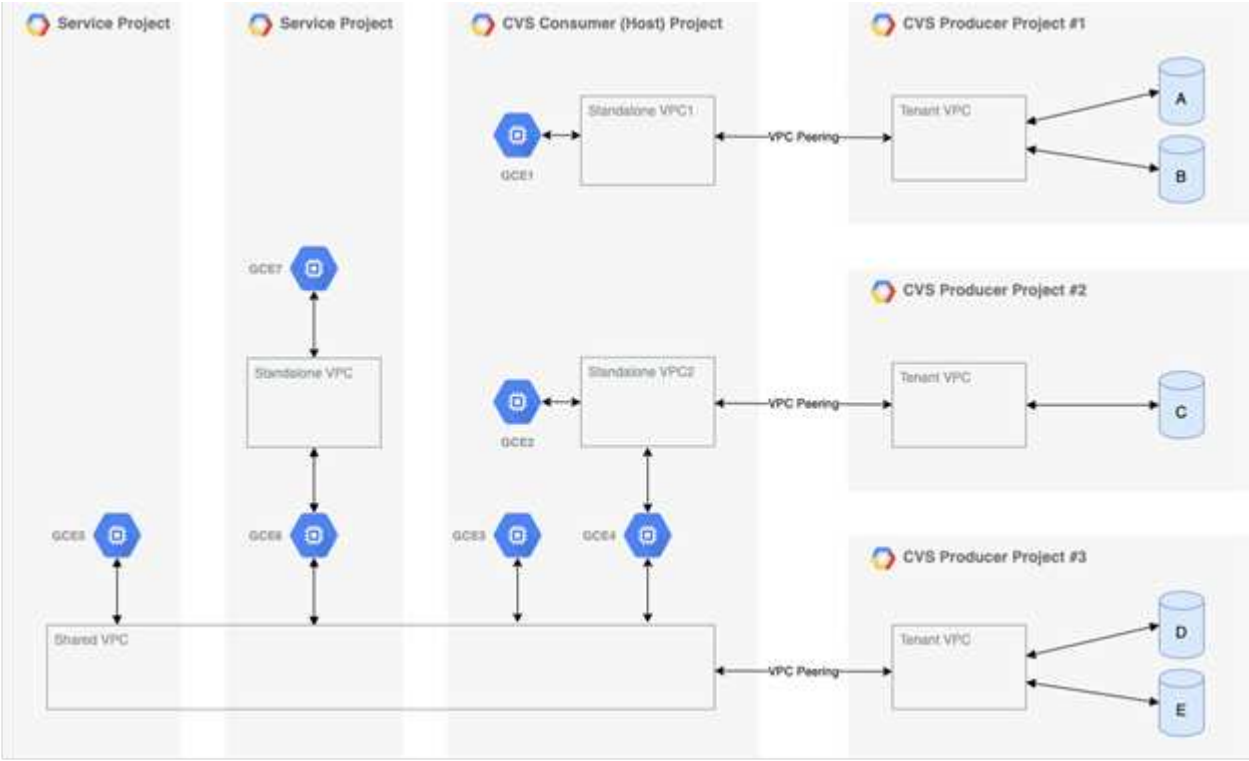
数据平台架构

"先前版本：控制平台架构。"

适用于Google Cloud的Cloud Volumes Service 利用了Google Cloud "私有服务访问" 框架。在此框架中、用户可以连接到Cloud Volumes Service。此框架像使用其他Google Cloud服务一样使用服务网络和VPC对等结构、确保租户之间完全隔离。

有关适用于Google Cloud的Cloud Volumes Service 架构概述、请参见 "适用于Cloud Volumes Service 的架构"。

用户vPC (独立或共享)与托管卷的Cloud Volumes Service 托管租户项目中的vPC建立对等关系。



上图显示了一个项目(中间为CVS使用者项目)、其中三个VPC网络连接到Cloud Volumes Service 、多个计算引擎VM (GCE1-7)共享卷：

- VC1允许GCE1访问卷A和B
- VPC2允许GCE2和GCE4访问卷C
- 第三个VPC网络是一个共享VPC、与两个服务项目共享。它允许GCE3、GCE4、GCE5和GCE6访问卷D和E只有CVS-Performance服务类型的卷才支持共享VPC网络。

GCE7无法访问任何卷。

可以在Cloud Volumes Service 中对传输中(使用Kerberos和/或SMB加密)和空闲数据进行加密。

"下一步：传输中的数据加密。"

传输中的数据加密

"先前版本：数据平面架构。"

传输中的数据可以在NAS协议层进行加密、Google Cloud网络本身也会进行加密、如以下各节所述。

Google Cloud网络

Google Cloud按中所述在网络级别对流量进行加密 "传输中加密" 在Google文档中。如"云卷服务架构"一节所述、Cloud Volumes Service 是通过NetApp控制的PSA生产商项目交付的。

对于CVS-SW、生产者租户运行Google VM来提供服务。Google会自动对用户VM和Cloud Volumes Service VM之间的流量进行加密。

虽然在网络层上、CVS-Performance的数据路径未完全加密、但NetApp和Google会结合使用 "IEEE 802.1AE加密(MAC秒)"， "封装" (数据加密)和受物理限制的网络、用于保护Cloud Volumes Service CVS-Performance服务类型与Google Cloud之间传输的数据。

NAS协议

NFS和SMB NAS协议可在协议层提供可选的传输加密。

SMB加密

"SMB加密" 为SMB数据提供端到端加密、并防止数据在不可信的网络上被窃听。您可以同时为客户端/服务器数据连接(仅适用于具有SMB3.x功能的客户端)和服务器/域控制器身份验证启用加密。

启用SMB加密后、不支持加密的客户端将无法访问共享。

Cloud Volumes Service 支持使用RC4 HMAC、AES-128-CTS-HMAC-SHA1和AES-256-CTS-HMAC-SHA1安全密码进行SMB加密。SMB协商到服务器支持的最高加密类型。

NFSv4.1 Kerberos

对于NFSv4.1、CVS-Performance可提供Kerberos身份验证、如中所述 "RFC7530"。您可以按卷启用Kerberos。

当前最强的Kerberos加密类型为AES-256-CTS-HMAC-SHA1。NetApp Cloud Volumes Service 支持适用于NFS的AES-256-CTS-HMAC-SHA1、AES-128-CTS-HMAC-SHA1、DES3和DES。它还支持对CIFS/SMB流量使用ARCFOUR-HMAC (RC4)、但不支持对NFS使用。

Kerberos为NFS挂载提供了三种不同的安全级别、这些安全级别可以选择Kerberos安全性的强程度。

根据RedHat的要求 "通用挂载选项" 文档：

```
sec=krb5 uses Kerberos V5 instead of local UNIX UIDs and GIDs to
authenticate users.
sec=krb5i uses Kerberos V5 for user authentication and performs integrity
checking of NFS operations using secure checksums to prevent data
tampering.
sec=krb5p uses Kerberos V5 for user authentication, integrity checking,
and encrypts NFS traffic to prevent traffic sniffing. This is the most
secure setting, but it also involves the most performance overhead.
```

一般来说、Kerberos安全级别必须执行的操作越多、性能就越差、因为客户端和服务器会花费时间对发送的每个数据包的NFS操作进行加密和解密。许多客户端和NFS服务器都支持将AES-NI负载分流到CPU、以获得更好的整体体验、但Kerberos 5p (完全端到端加密)的性能影响远远大于Kerberos 5 (用户身份验证)的影响。

下表显示了每个级别在安全性和性能方面的差异。

安全级别	安全性	性能
NFSv3—系统	• 安全性最低；纯文本、包含数字用户ID/组ID • 能够查看UID、GID、客户端IP地址、导出路径、文件名、 数据包捕获中的权限	• 最适合大多数情况
NFSv4.x—系统	• 比NFSv3 (客户端ID、名称字符串/域字符串匹配)更安全、但仍为纯文本 • 能够查看UID、GID、客户端IP地址、名称字符串、域ID、 数据包捕获中的导出路径、文件名和权限	• 适用于顺序工作负载(如VM、数据库、大型文件) • 错误、文件数量较多/元数据较高(较差30-50%)
NFS—krb5	• 对每个NFS数据包中的凭据进行Kerberos加密—在GSS包装程序中的RPC调用中封装用户/组的UID/GID • 请求访问挂载的用户需要有效的Kerberos票证(通过用户名/密码或手动密钥选项卡交换)；票证将在指定时间段后过期、用户必须重新进行身份验证才能进行访问 • 对于NFS操作或挂载/端口映射程序/NLM等辅助协议、不进行加密(可以查看导出路径、IP地址、文件句柄、权限、文件名、数据包捕获中的atime/mtime)	• 大多数情况下最适合使用Kerberos；比AUTH_SYS更差

安全级别	安全性	性能
NFS—krb5i	• 对每个NFS数据包中的凭据进行Kerberos加密—在GSS包装程序中的RPC调用中封装用户/组的UID/GID • 请求访问挂载的用户需要有效的Kerberos票证(通过用户名/密码或手动密钥选项卡交换)；票证将在指定时间段后过期、用户必须重新进行身份验证才能访问 • 对于NFS操作或挂载/端口映射程序/NLM等辅助协议、不进行加密(可以查看导出路径、IP地址、文件句柄、权限、文件名、数据包捕获中的atime/mtime) • 每个数据包都会添加Kerberos GSS校验和、以确保不会截获任何数据包。如果校验和匹配、则允许对话。	• 优于krb5p、因为NFS有效负载未加密；与krb5相比、唯一增加的开销是完整性校验和。krb5i的性能不会比krb5差得多、但会有所下降。
NFS—krb5p	• 对每个NFS数据包中的凭据进行Kerberos加密—在GSS包装程序中的RPC调用中封装用户/组的UID/GID • 请求访问挂载的用户需要有效的Kerberos票证(通过用户名/密码或手动密钥表交换)；票证将在指定时间段后过期、用户必须重新进行身份验证才能进行访问 • 所有NFS数据包有效负载都使用GSS包装程序进行加密(在数据包捕获中看不到文件句柄、权限、文件名、atime/mtime)。 • 包括完整性检查。 • NFS操作类型是可见的(fsINFO、access、getattr等)。 • 辅助协议(挂载、端口映射、NLM等)未加密-(可以查看导出路径、IP地址)	• 安全级别的性能最差；krb5p必须对更多内容进行加密/解密。 • 对于文件数量较多的工作负载、性能优于使用NFSv4.x时的krb5p。

在Cloud Volumes Service 中、配置的Active Directory服务器用作Kerberos服务器和LDAP服务器(从RFC2307兼容模式查找用户身份)。不支持其他Kerberos或LDAP服务器。NetApp强烈建议您在Cloud Volumes Service 中使用LDAP进行身份管理。有关NFS Kerberos在数据包捕获中的显示方式的信息、请参见一节 "《数据包嗅探/跟踪注意事项》。"

"下一步：空闲数据加密。"

空闲数据加密

"先前版本：传输中的数据加密。"

Cloud Volumes Service 中的所有卷都使用AES-256加密进行空闲加密、这意味着写入介质的所有用户数据都将进行加密、并且只能使用每个卷的密钥进行解密。

- 对于CVS-SW、使用Google生成的密钥。
- 对于CVS-Performance、每个卷的密钥存储在Cloud Volumes Service 中内置的密钥管理器中。

自2021年11月起、提供了预览客户管理的加密密钥(CMEK)功能。这样、您就可以使用中托管的每个项目的每个区域主密钥对每个卷的密钥进行加密 "Google密钥管理服务(KMS)。" 您可以通过Kms连接外部密钥管理器。

有关为KMS配置CVS-Performance的信息、请参见 "设置客户管理的加密密钥"。

"下一步：防火墙。"

防火墙：

"先前版本：空闲数据加密。"

Cloud Volumes Service 公开多个TCP端口以提供NFS和SMB共享：

- "NFS访问所需的端口"
- "SMB访问所需的端口"

此外、SMB、包含Kerberos的LDAP NFS以及双协议配置都需要访问Windows Active Directory域。Active Directory连接必须为 "已配置" 按区域计算。Active Directory域控制器(DC)通过使用进行标识 "基于DNS的DC发现" 使用指定的DNS服务器。将使用返回的任何DC。可以通过指定Active Directory站点来限制符合条件的域控制器列表。

Cloud Volumes Service 会通过使用`gcloud compute address`命令分配的CIDR范围内的IP地址进行联系 "加入Cloud Volumes Service"。您可以使用此CIDR作为源地址来为Active Directory域控制器配置入站防火墙。

Active Directory域控制器必须 "将端口公开到此处所述的Cloud Volumes Service CIDR中"。

"接下来：NAS协议概述。"

版权信息

版权所有©2022 NetApp、Inc.。保留所有权利。Printed in the U.S.版权所涵盖的本文档的任何部分不得以任何形式或任何手段复制、包括影印、录制、 磁带或存储在电子检索系统中—未经版权所有者事先书面许可。

Software derived from copyrighted NetApp material is subject to the following license and disclaimer:

本软件由NetApp按"原样"提供、不含任何明示或默示担保、包括但不限于适销性和特定用途适用性的默示担保、特此声明不承担任何责任。IN NO EVENT SHALL NETAPP BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

NetApp reserves the right to change any products described herein at any time, and without notice.NetApp assumes no responsibility or liability arising from the use of products described herein, except as expressly agreed to in writing by NetApp.The use or purchase of this product does not convey a license under any patent rights, trademark rights, or any other intellectual property rights of NetApp.

The product described in this manual may be protected by one or more U.S.patents, foreign patents, or pending applications.

RESTRICTED RIGHTS LEGEND: Use, duplication, or disclosure by the government is subject to restrictions as set forth in subparagraph (c)(1)(ii) of the Rights in Technical Data and Computer Software clause at DFARS 252.277-7103 (October 1988) and FAR 52-227-19 (June 1987).

商标信息

NetApp、NetApp标识和中列出的标记 http://www.netapp.com/TM 是NetApp、Inc.的商标。其他公司和产品名称可能是其各自所有者的商标。